

Received 10 February 2026, accepted 6 April 2026, date of publication 14 April 2026, date of current version 28 April 2026.

Digital Object Identifier 10.1109/ACCESS.2026.3684011

RESEARCH ARTICLE

Self-Sovereign Identity as a Governance Model for Digital Identity and Privacy in the Metaverse

SALVATORE SAIU^{ID}, MAURO FADDA^{ID}, (Senior Member, IEEE), PIETRO RUIU^{ID}, AND ENRICO GROSSO^{ID}

Engineering Department, University of Sassari, 07100 Sassari, Italy

Corresponding author: Salvatore Saiu (salsaiu@uniss.it)

This work was supported in part by the National Recovery and Resilience Plan (NRRP), Mission 4, Component 2, Investment 1.1, Call for tender No. 1409, published on October 2022, by the Italian Ministry of University and Research (MUR), funded by the European Union—NextGenerationEU—Project Title “METATwin—Metaverse and Human Digital Twin: digital identity, Biometrics, and Privacy in the Future Virtual Worlds,” under Grant CUP J53D23015030001; and in part by MUR, in October 2023, under Grant 0001382.

ABSTRACT The emergence of the Metaverse as a persistent, immersive, and interoperable digital ecosystem introduces system-level challenges in identity management, security, and privacy protection across networked extended reality environments. Current platforms predominantly rely on centralized or proprietary identity infrastructures, limiting interoperability, reducing user control, and increasing exposure to large-scale behavioral and biometric data collection. This paper presents a system-level research contribution that investigates Self-Sovereign Identity (SSI) as a secure and privacy-preserving identity infrastructure for Metaverse and Extended Reality (XR) systems. Building on an analysis of SSI components and existing Metaverse architectures, the work proposes a modular SSI-based reference architecture integrating decentralized identifiers, verifiable credentials, selective disclosure mechanisms, and DIDComm-based secure messaging. A healthcare-oriented immersive use case illustrates real-time credential exchange and consent-driven data minimization in latency-sensitive clinical consultations. Furthermore, the paper introduces an analytical and comparative risk-assessment framework spanning device, infrastructure, communication, and service layers, operationalized through Service-Level Indicators and Service-Level Objectives to quantify resilience and compliance properties. Comparative evaluation against traditional Electronic Health Record (EHR)-based identity models indicates that SSI-based pipelines significantly reduce systemic exposure, particularly with respect to device security, communication integrity, and consent governance. Overall, the results highlight SSI as a viable foundation for secure, interoperable, and privacy-preserving identity management in networked Metaverse environments, while outlining current limitations and directions for future deployment and standardization.

INDEX TERMS Self-sovereign identity, metaverse, extended reality security, digital identity, privacy-preserving systems.

I. INTRODUCTION

The Metaverse (MV), defined as “a persistent, shared, and interoperable network of three-dimensional virtual worlds, which integrates physical and digital realities, enabling users to interact with each other and digital objects in real time through immersive technologies” [1] is rapidly emerging as a credible paradigm for the design of next-generation socio-technical systems [2]. The classical conception of the

Metaverse envisions a three-dimensional reconstruction of an environment that closely mirrors the physical reality in which we live. However, the contemporary understanding of the Metaverse extends far beyond a single, monolithic platform. It is better described as a heterogeneous technological ecosystem, integrating multiple extended reality (XR) development frameworks, interconnected virtual environments, and a variety of delivery channels.

The Metaverse of the future is likely to evolve into a highly immersive, persistent, and interoperable digital environment, seamlessly blending augmented, virtual, and

The associate editor coordinating the review of this manuscript and approving it for publication was Tariq Masood^{ID}.

mixed reality technologies with advanced artificial intelligence, blockchain-based infrastructures, and high-speed network connectivity. Unlike the relatively isolated platforms of today, future iterations are expected to support full interoperability, allowing users to carry their digital identities, assets, and experiences across multiple virtual worlds without fragmentation.

In such an environment, individuals will not only engage in social interaction and entertainment but also participate in a wide range of professional, educational, and creative activities. We might attend immersive virtual conferences, collaborate in real time on complex engineering projects, explore interactive simulations for scientific research, or experience hyper-personalized learning environments.

In the healthcare sector, augmented reality systems could assist a team of surgeons during operations, enhancing their capabilities by providing supplementary visual perspectives or suggesting precise actions to undertake. Other applications envision conducting remote medical consultations, where patient data can be integrated and presented in immersive formats, thereby improving diagnostic and therapeutic decision-making. Such developments align with broader advances in telemedicine, potentially expanding access to high-quality healthcare across geographic and logistical barriers.

Moreover, commerce will be deeply integrated, enabling secure peer-to-peer transactions, virtual property ownership, and entirely new economic models. The Metaverse could thus become a central infrastructure for social, economic, and cultural exchange, functioning as both an extension and a transformation of our physical reality.

While many applications already exist, the technology is not yet fully mature. The realization of a truly pervasive and seamless Metaverse will require low-latency network infrastructures, high computational power, and non-intrusive wearable devices. These components are essential to ensure real-time interaction, high-fidelity immersive experiences, and prolonged usability without discomfort, thereby enabling the Metaverse to reach its full potential across diverse domains. In this context, immersive Metaverse and XR platforms should be interpreted as distributed, networked, and latency-sensitive systems, rather than purely virtual environments. Real-time avatar interaction, continuous session states, cross-platform access, and dynamic data exchange introduce constraints typical of large-scale networked systems, including trust distribution, session continuity, replay resistance, and resilience to partial failures. Within such environments, digital identity functions as a security and authorization control plane, governing authentication, access decisions, and data disclosure across heterogeneous devices and infrastructures. From this perspective, Self-Sovereign Identity (SSI) can be regarded as a distributed trust infrastructure enabling verifiable, privacy-preserving interactions without reliance on centralized identity providers. Rather than addressing identity governance at a purely conceptual level, this work focuses on the system-level integration of SSI into XR pipelines, analyzing how decentralized identifiers,

verifiable credentials, and secure messaging protocols can support robust identity management in networked immersive applications. However, the most pressing challenge for the Metaverse is likely to concern the security and integrity of digital identities. Immersive technologies such as VR and AR rely on extensive data collection, capturing not only eye movements, facial expressions, posture, and voice, but also precise geolocation and behavioral patterns. These datasets, while essential for delivering realistic and personalized experiences, can inadvertently reveal deeply personal information, including health conditions and psychological traits. Advanced machine learning techniques can process this data to construct highly detailed psychological and behavioral profiles. While such profiling can enhance user experiences, it also exposes individuals to significant risks of manipulation, discrimination, or targeted exploitation. Furthermore, the push towards interoperability across different Metaverse platforms introduces additional vulnerabilities. Cross-platform credential management, if not secured with robust mechanisms, increases the likelihood of large-scale credential stuffing and coordinated cyberattacks. Protecting personal data in the Metaverse will require a paradigm that prioritizes user sovereignty over information. Individuals must retain ownership of their digital identities, with the ability to determine precisely what data is shared, with whom, and under what conditions. Achieving this will likely involve the adoption of decentralized identity frameworks, in which authentication and verification are managed through cryptographic protocols rather than centralized repositories vulnerable to breaches. Such systems could leverage blockchain-based SSI models, enabling users to store credentials in secure digital wallets and disclose only the minimum necessary information for a given interaction. Interacting safely with Metaverse applications will also depend on the implementation of fine-grained consent management tools, privacy-preserving computation techniques, and zero-knowledge proofs, which allow verification without revealing the underlying data. Moreover, robust encryption for both data at rest and data in transit will be essential to prevent unauthorized access. Given the abundance of personal information generated and exchanged in immersive environments, coupled with the current lack of universal standards and the heightened security risks, the development of secure, interoperable, and resilient data governance solutions is imperative. Without such measures, the Metaverse risks becoming a fragmented and insecure space, undermining user trust and limiting its long-term potential. This work proposes a novel framework for managing data shared within a Metaverse application by leveraging the SSI paradigm. In this approach, SSI is not employed merely as an authentication mechanism, but as a comprehensive model in which users can issue, present, and revoke credentials for any purpose requiring the verification of identity or specific attributes. This framework empowers individuals with granular control over their personal data, ensuring that identity-related interactions within the Metaverse are both

secure and aligned with user-defined consent. The core contributions of this work are as follows:

- 1) A modular reference architecture for SSI-enabled Metaverse and XR systems, integrating decentralized identifiers, verifiable credentials, selective disclosure mechanisms, and secure messaging into a layered, platform-agnostic design tailored to networked immersive environments.
- 2) A healthcare-oriented immersive use case demonstrating secure, real-time, and consent-driven credential exchange between distributed actors, illustrating how SSI can support privacy-preserving data access in latency-sensitive XR clinical consultations.
- 3) An analytical and comparative risk-assessment model, grounded in Service-Level Indicators (SLIs) and Service-Level Objectives (SLOs), enabling the quantitative evaluation of resilience and security exposure across SSI-based and traditional EHR-based identity pipelines.

II. BACKGROUND

Self-Sovereign Identity (SSI) is an emerging paradigm that enables individuals to manage and control their digital identities without relying on centralized authorities or platform-specific identity providers. Built on decentralized cryptographic primitives such as Decentralized Identifiers (DIDs), Verifiable Credentials (VCs), and secure exchange protocols like DIDComm v2, SSI supports privacy-preserving authentication, selective disclosure, and verifiable credential presentation without requiring pre-established trust relationships between parties [3]. Within this paradigm, Verifiable Data Registries (VDRs), often backed by blockchain or distributed ledger infrastructures, anchor credential schemas, DID documents, and revocation artefacts, allowing verifiers to independently validate authenticity and status proofs without contacting issuers [4]. As such, SSI moves beyond traditional identity management by enabling identity portability, long-term lifecycle governance, and user-mediated consent across application contexts.

Recent literature highlights the increasing relevance of SSI in regulated and high-assurance domains. In finance, SSI-based identity credentials have been explored to enhance user-controlled onboarding and authorization models while avoiding reliance on centralized identity providers [5]. Within healthcare, decentralized identity systems have been proposed to enable secure and privacy-preserving exchange of clinical or medical credentials, reducing exposure to centralized breaches and improving consent control [6], [7], [8]. Educational ecosystems have adopted verifiable credentials for diploma and micro-credential portability, enabling cross-platform verification without institutional gatekeepers [9], [10]. Complementarily, several studies emphasize the suitability of decentralized identity for metaverse-related healthcare and telemedicine use cases,

highlighting how immersive ecosystems amplify data sensitivity and context-dependent access requirements [11], [12]. In parallel, public-sector digital identity strategies progressively align with SSI principles, positioning decentralized identity as a foundation for interoperable, cross-jurisdiction infrastructures.

Despite this maturity, SSI integration into immersive, persistent, and interaction-rich Metaverse or XR ecosystems remains limited and conceptually fragmented. Existing research often focuses on distinct dimensions: conceptual governance and identity framing [13], cross-platform avatar interoperability mechanisms [14], trust and onboarding models for virtual environments [15], or decentralized authorization schemes [16]. Surveys and conceptual analyses confirm that while the Metaverse has become an architectural and socio-technical focal point, identity remains largely dependent on centralized, platform-bound trust infrastructures [1]. Furthermore, recent privacy analyses highlight how behavioral, biometric, and cognitive signals recorded by immersive systems require selective disclosure, minimization, and verifiable usage policies to avoid irreversible privacy erosion [17]. These evidences show that SSI principles are promising for the Metaverse but have not yet been translated into full-stack implementations capable of supporting real-time spatial interactions, multi-agent workflows, or adaptive, session-bound consent flows.

This research builds on the premise that identity management for the Metaverse cannot rely on solutions originally designed for web-based authentication. Immersive systems introduce embodied presence, continuous session states, avatar continuity, and mixed interaction modalities, demanding identity protocols that do not assume stable connectivity, centralized brokers, or static trust anchors. While SSI theoretically satisfies decentralization and verifiable consent requirements, practical adoption demands architectural adaptations such as interaction-aware credential negotiation, context-binding, and lightweight verification optimized for real-time XR workloads.

In addition, immersive identity systems must reflect contextual integrity: user data should be disclosed only with respect to situational relevance, social norms, and operational purpose. Although selective disclosure and verifiable presentations theoretically enable such constraints, most existing SSI implementations rely on traditional interfaces and do not address embodied or continuous interaction loops. Conversely, current XR identity solutions optimize onboarding and continuity but rarely integrate minimization, revocability, or formal auditability. These limitations highlight the need for architectures that embed SSI capabilities directly within immersive interaction pipelines, thereby reconciling usability, privacy, and cross-platform interoperability.

The architecture proposed in this work addresses these gaps by embedding SSI agents, verifiable presentation protocols, and contextual disclosure models natively within XR interaction loops. Through this approach, identity verification becomes user-controlled, portable, and cryptographically

anchored to decentralized registries, aligning immersive environments with privacy-by-design principles and enabling trustworthy, modular, and interoperable identity management tailored to Metaverse-scale ecosystems.

III. IDENTITY AND PRIVACY CHALLENGES IN THE METAVERSE

Digital identity and privacy management remain among the most critical and unresolved challenges in Metaverse development. Current identity architectures are largely centralized and platform-dependent, resulting in limited interoperability, reduced user control, and significant barriers to regulatory compliance, especially in sensitive domains such as healthcare and education [18].

In platforms like Meta's Horizon Worlds or Roblox, user credentials and social identities are tightly coupled with proprietary ecosystems. While this model simplifies onboarding and moderation, it also enables large-scale profiling, cross-context tracking, and limited transparency regarding data usage [19], [20].

From a security and privacy standpoint, these architectures suffer from three main limitations:

- 1) Lack of portability: users cannot transfer avatars or credentials across platforms, reinforcing vendor lock-in;
- 2) Absence of selective disclosure: systems do not support granular consent or attribute sharing, increasing privacy risks;
- 3) Opaque trust anchors: centralized authorities limit auditability and weaken large-scale trust assurance [18].

SSI offers a promising alternative by decentralizing control over identity data. Through DIDs, VCs, and cryptographic communication protocols, it enables auditable and privacy-preserving identity exchanges [21].

A core strength of SSI lies in its alignment with the data minimization principle defined in Article 5(1)(c) of the GDPR. SSI allows users to disclose only attributes necessary for a specific interaction, e.g., proving legal age without revealing the exact date of birth, thus reducing unnecessary data exposure and ensuring compliance with privacy-by-design principles.

In this way, SSI not only enhances portability and interoperability but also embeds privacy protection at the architectural level, providing a robust foundation for trust, autonomy, and governance in the emerging Metaverse ecosystem.

A. COMPARISON WITH EXISTING METAVERSE PLATFORM AND SSI COMPLIANCE

This section evaluates the extent to which current Metaverse platforms implement, or fail to implement, SSI mechanisms such as Decentralized Identifiers (DIDs) and Verifiable Credentials (VCs).

The comparative analysis presented in Table 3 reveals that the majority of leading Metaverse platforms continue to rely on centralized or federated identity models, with limited or no support for SSI principles. Platforms such as Horizon Worlds, Roblox, VRChat, and Spatial are primarily based on proprietary or third-party identity providers, thereby constraining user autonomy and reinforcing dependence on external entities. By contrast, Decentraland and Somnium Space introduce wallet-based authentication mechanisms, aligning more closely with Web3 paradigms; however, their integration of decentralized identifiers (DIDs) and verifiable credentials (VCs) remains experimental or incomplete. Moreover, interoperability with SSI Agents is either absent or marginal, underscoring the immaturity of current solutions in enabling user-controlled, verifiable, and portable digital identities. These findings highlight a significant gap between the state of existing Metaverse identity infrastructures and the requirements for privacy-preserving, interoperable SSI systems. Consequently, they substantiate the relevance of the architectural framework advanced in this work, which directly addresses these limitations by embedding DID, VC, and SSI Agent support into the Metaverse data management layer.

IV. PROPOSED ARCHITECTURE

Designing a secure and interoperable Metaverse identity infrastructure requires the coordinated integration of identity management, real-time rendering, communication protocols, and user consent mechanisms. The architecture proposed in this work addresses this challenge through a modular, layered, and platform-agnostic system design that uses Unity as the core rendering engine and SSI as the foundation for trust, authentication, and data authorization.

At a high level, the architecture is organized into four logically distinct layers: the User Layer (credential management, secure storage, cryptography, and selective disclosure), the SSI Layer (DID and VC management, digital identity, verifiable presentation construction, consent, and DIDComm), the Metaverse Layer (Unity engine, authentication, data visualization, and 3D scenes with avatars), and the Trust and Registry Layer (verifiable data registries, blockchains, and issuers). Fig. 1 depicts the model and interconnections which highlight data flows, status proofs, and consent policies required to ensure trust, interoperability, and security.

The User Layer is responsible for the direct management of VCs. All credentials received by the user whether issued by trusted authorities or exchanged with peers are retained within a protected environment, typically a digital wallet integrated into the device or the application itself. This storage relies on cryptographic safeguards, ensuring that VCs remain encrypted and accessible only to the authorized user. The wallet preserves both integrity and availability, preventing tampering and allowing credentials to be retrieved whenever needed for presentation or verification. Thanks to the selective disclosure, the user can exercise granular control over the information revealed in specific interactions. Instead

TABLE 1. Evaluation of SSI adoption across leading Metaverse platforms.

Platform	Identity Model	External Support	IdP	Native DID / VC Support	User-Controlled Wallet	Interoperability with SSI Agents	Reference
Horizon Worlds	Centralized (Meta ID)	Meta (proprietary federation)	SSO	Not supported	Not available	Absent	Meta Docs (2023)
Roblox	Internal proprietary credentials	Not supported		Not supported	Not available	Absent	Roblox (2023); DevHub (2023); Laborde et al. (2023)
Decentraland	Wallet-based (Ethereum)	Not applicable		Experimental integration plugins	Supported via Metamask	Partial support through custom modules	Ruiu et al. (2024); Decentraland Docs (2024)
VRChat	Centralized (email/password)	Optional OAuth2 (Google)		Not supported	Not available	Absent	VRChat Support (2024)
Spatial	Centralized (Google/Apple SSO)	OAuth2 / OIDC federation		Not supported	Not available	Absent	Spatial Docs (2023)
Somnium Space	Wallet-based (Web3 login)	Not applicable		Planned (no active DID infrastructure)	Supported via crypto wallets	Limited (no verifiable credential support)	Somnium Docs (2024); Flamini et al. (2024)

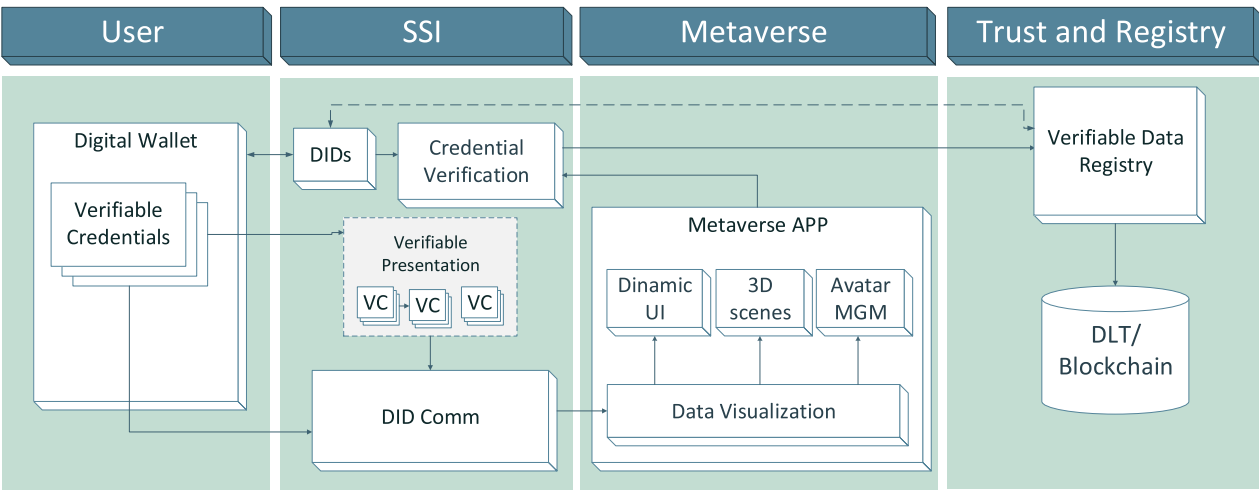


FIGURE 1. Multilayer architecture for SSI management in the Metaverse.

of disclosing an entire credential, the user can inspect its content and elect to reveal only the attributes pertinent to a given context.

SSI layer manages DIDs, VCs, credential verification protocols and DIDComm messaging. SSI agents (e.g., based on Veramo or Hyperledger Aries) handle key lifecycle operations, DID resolution, and credential presentation. Trust is derived from cryptographic assurances and the verifiability of credentials issued by recognized authorities. Moreover, this layer governs the contextual disclosure of data. Users control the construction and sharing of Verifiable Presentations (VPs) that selectively include attributes based

on interaction type and consent status. Consent is mediated through in-environment prompts, visual cues, and revocation interfaces, in compliance with data minimization and purpose limitation principles under regulations such as GDPR and HIPAA.

The Metaverse Layer is built on the Unity engine and renders 3D scenes, avatar states, and data visualizations. It embeds dynamic UI components for in-world credential exchange, consent visualization, and identity status indicators (e.g., verified badges, pseudonymity modes). It also handles synchronization of user input, environment state, and avatar behavior in real time.

The Trust and Registry Layer provides the foundational infrastructure that enables the reliability, transparency, and verifiability of the entire SSI ecosystem. Within this layer operate entities such as the Issuer, the Verifiable Data Registry (VDR), and the Blockchain, each contributing to the establishment and maintenance of trust. The Issuer is responsible for generating and digitally signing Verifiable Credentials, thereby guaranteeing their provenance and authenticity. The VDR serves as a decentralized registry where essential metadata such as DID documents, credential schemas, and revocation information is stored and made universally accessible. This registry does not contain the credentials themselves but instead provides the references and cryptographic material required for their verification. The Blockchain underpins the VDR by offering immutability, decentralization, and auditability, ensuring that identifiers, credential status, and verification events cannot be altered retroactively and remain available to all participants.

A. SELECTIVE DISCLOSURE IMPLEMENTATION

A key requirement for privacy-preserving interactions in SSI-based systems is the ability to disclose only specific, relevant information rather than entire credentials. Within the context of the metaverse, where immersive interactions often require identity validation, selective disclosure ensures that sensitive information remains protected while supporting secure and verifiable exchanges.

The proposed solution incorporates a dedicated component, referred to as the SSI Agent, which functions as an intermediary between users, verifiable credentials, and the underlying trust infrastructure. The SSI Agent is responsible for the management of DIDs, the facilitation of secure communication channels through DIDComm, and the support of credential issuance and verification processes. Furthermore, it enforces selective disclosure policies, thereby ensuring that only the necessary information is revealed during interactions.

In Fig. 2, the selective disclosure functionality in a generic Metaverse application involving two users is depicted. The flow begins with User_0 requesting credentials from User_1 via SSI Agent 0 (steps 1–2). User_1 selects disclosure fields and establishes a DIDComm channel using DID User_0 (steps 3–4). A derived verifiable presentation (VP) signed with DID User_1 is created (step 5) and sent with selected claims (step 6). The system resolves DID User_1 and checks its status on the VDR Blockchain before SSI Agent 0 verifies the VP's signature and integrity (steps 7–8). This ensures authenticity, trust, and secure identity management.

B. USE CASE: SECURE SHARING IN METAVERSE CLINICAL CONSULTATIONS

To validate the applicability of the proposed architecture, we present a healthcare-oriented use case that demonstrates the secure, real-time, and privacy-preserving exchange of medical data during a clinical consultation. Two authenticated participants a patient and a clinician, such as a specialist

doctor interact via avatars in a Unity-based environment. The patient uses a Meta Quest 3 headset; the clinician operates through a Microsoft HoloLens 2. Both devices are integrated with biometric sensing and SSI infrastructure. Assume that the patient is required to present certain medical examinations or certificates to the specialist physician, which are in the patient's possession and, for instance, stored within their digital wallet.

Fig. 3 illustrates the process of employing DIDs and VCs within a generic healthcare setting, thereby enabling the mapping of the principal SSI roles in this context. A general practitioner, acting as the issuer, provides a patient (the DID Subject) with a verifiable credential in the form of a digital medical certificate. The patient can then present this credential to a specialist doctor (for example in a Metaverse environment), who serves as the verifier. To ensure authenticity, the verifier checks the credential against the patient's DID document and the verifiable data registry, which contain the cryptographic keys and verification mechanisms.

In this scenario, the VC is represented by a medical certificate, but it could equally consist of any other type of data, such as a medical report, the result of a clinical test, three-dimensional data such as CT scans or X-rays, or other information that may be stored within the digital medical record. Upon session initiation, both users authenticate locally through biometric or cryptographic methods (e.g., FIDO2, fingerprint scan), triggering a session-level binding to Decentralized Identifiers (DIDs) resolved via identity wallets. The clinician requests access to selected data (e.g., medical report, the result of a clinical test, imaging data such as CT scans or X-rays), encapsulated in a DIDComm v2 credential request. This request, transmitted securely to the patient's SSI agent, is surfaced within the Unity interface as a contextual consent prompt, presenting metadata including the issuer's DID, trust level, and declared purpose.

The patient selects specific attributes to disclose. A Verifiable Presentation (VP) is dynamically constructed and signed via the patient's private key. The VP is sent back to the clinician, who verifies it using the VDR. Upon successful verification, authorized data are visualized within the interface. At session end, credential flows and consent actions are recorded in local audit logs with tamper-evident mechanisms (e.g., hash chains), ensuring traceability and supporting GDPR/HIPAA compliance. Session tokens are invalidated to prevent reuse or unauthorized replay. This scenario illustrates how decentralized identity, credential-based access, and immersive consent mechanisms can be tightly integrated to support real-time, privacy-respecting HDT interactions. Clinicians benefit from timely, verifiable patient data, while patients retain granular control over what is shared, with whom, and under which terms.

V. RISK TAXONOMY

While the previous sections introduced the architectural foundations of the proposed framework, a rigorous evaluation requires moving beyond design principles toward a

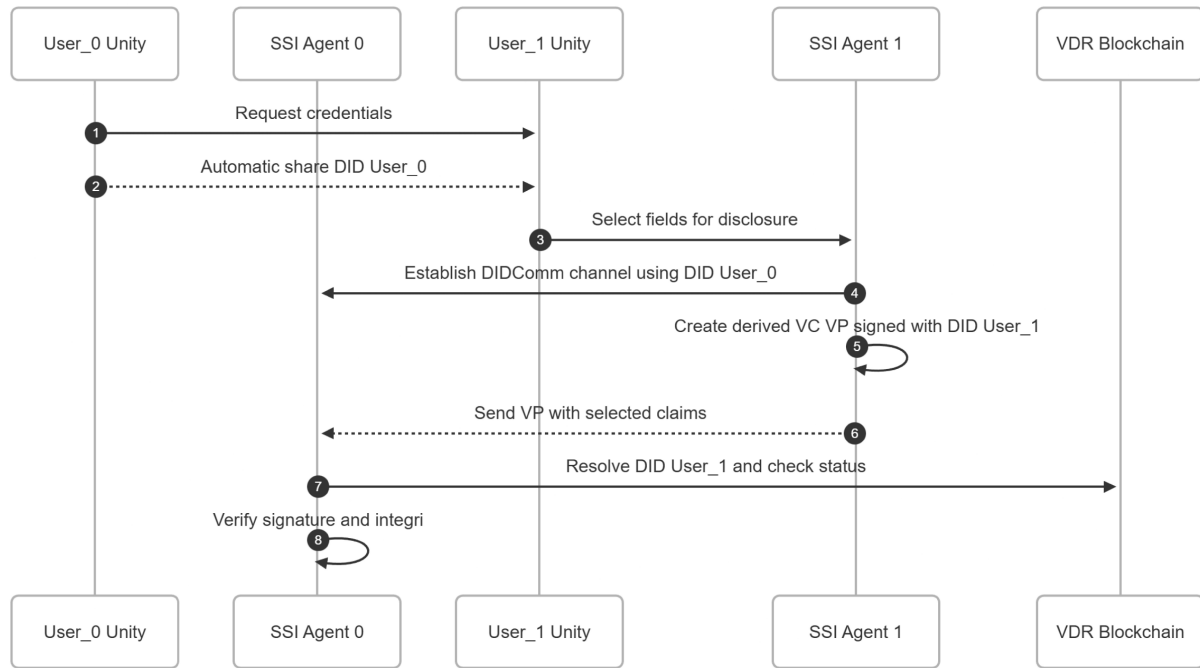


FIGURE 2. Sequence diagram illustrating the credential exchange and verification process in a SSI framework within the metaverse.

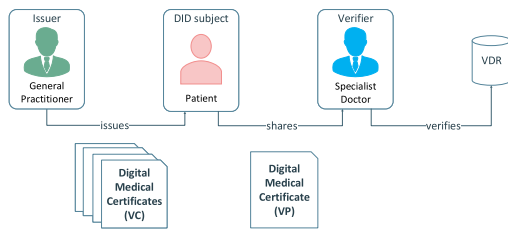


FIGURE 3. Verifiable credentials flow in a healthcare context.

systematic understanding of where and how risks emerge along the identity pipeline. This section introduces a risk taxonomy that classifies potential threats and vulnerabilities across four interdependent domains: **Device**, **Infrastructure**, **Communication**, and **Services**. Each domain captures a distinct exposure layer, from device compromise and protocol-level attacks to over-disclosure and consent fatigue in immersive interfaces. Building on this taxonomy, we define an operational evaluation model based on Service-Level Indicators (SLIs) and Service-Level Objectives (SLOs), translating qualitative regulatory principles (GDPR, HIPAA, W3C VC Model, NIST SP 800-63B) into measurable constructs for assessing robustness and compliance.

For this study, we focus on the four macro-blocks mentioned above, each representing a specific class of vulnerabilities while remaining interdependent within the end-to-end workflow. Recognizing this interplay ensures that both technical and governance-level weaknesses are jointly evaluated under each block's score R_b in Section VI.

Figure 4 illustrates the four macro-blocks that structure the system, each representing a major domain in which specific security vulnerabilities and risks can arise.

Device. This block includes the user's physical access points (e.g., PCs, smartphones, and XR headsets) which constitute the first line of exposure. They handle sensitive data such as biometrics, behavioral telemetry, and cryptographic keys. Risks include malware infection, hardware tampering, weak authentication, or side-channel attacks, all of which may compromise data confidentiality and credential integrity.

Infrastructure. This domain covers the blockchain-based verifiable data registries and the Metaverse runtime. Threats include smart contract flaws, consensus manipulation, or insufficient scalability on the blockchain side, and integrity or persistence issues within the virtual environment. Centralized dependencies or identity spoofing further undermine the decentralization and trust guarantees SSI aims to provide.

Communication. This block encompasses the transport and messaging layer, primarily DIDComm over standard Internet infrastructure (4G/5G and beyond). Risks include man-in-the-middle attacks, replay, traffic analysis, and latency-related failures. Because credential exchange and consent negotiation are time-sensitive in immersive environments, weaknesses here can degrade both trust guarantees and user experience.

Services. This layer includes the SSI agent and the healthcare consultation application used in the reference scenario. Risks stem from weak access control, insufficient session isolation, or improper integration of SSI components within XR environments. The agent must enforce selective disclosure and revocation consistently, while surrounding services must handle consent and logging in a tamper-evident manner to ensure compliance with GDPR and HIPAA.

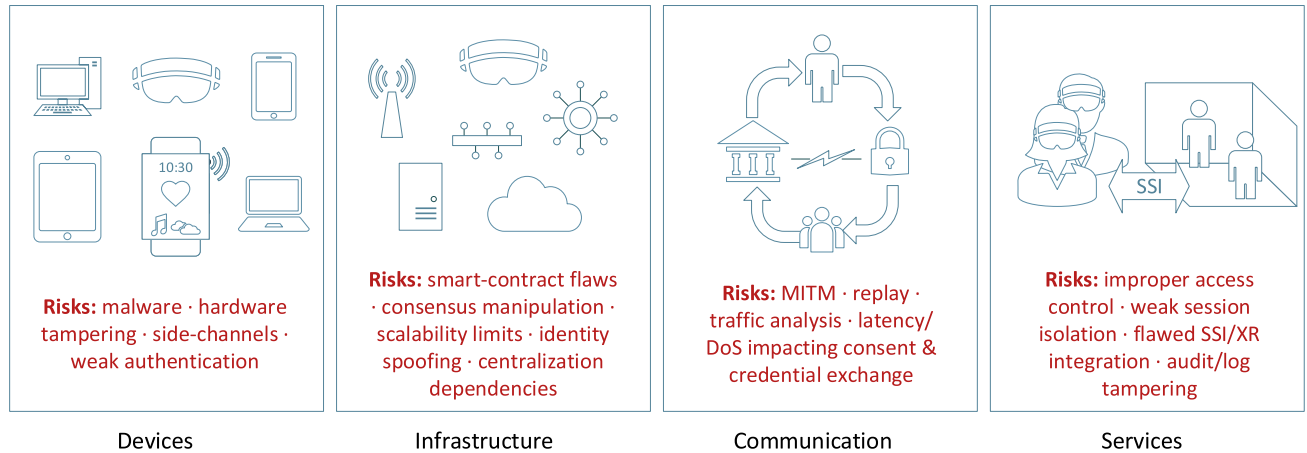


FIGURE 4. Overview of the four macro-blocks considered in the study, each representing a distinct yet interdependent class of vulnerabilities and associated security risks.

Beyond purely technical risks, immersive systems introduce human-in-the-loop vulnerabilities linked to consent behavior and user attention. In XR workflows, consent is continuous and multimodal, via gaze, gesture, or controller input, which can lead to cognitive overload and “consent fatigue.” Users may unknowingly approve excessive disclosures, undermining data-minimization principles. These behavioral risks, captured mainly in the Services block, can be measured through SLI/SLO indicators such as consent usability, prompt frequency, and response latency.

This taxonomy provides the conceptual foundation for the quantitative risk assessment detailed in the following section.

A. OPERATIONAL METRICS AND SERVICE-LEVEL TARGETS

To operationalize the taxonomy of risks introduced above and ground the assessment in measurable constructs, each macro-block (Device, Infrastructure, Communication, Services) is associated with **Service-Level Indicators (SLIs)** and corresponding **Service-Level Objectives (SLOs)**. SLIs are observable constructs defined from the architectural workflow and are used to parameterize the threat probabilities p_t ; SLOs define qualitative objectives representing acceptable risk levels.

Together, SLIs and SLOs enable the estimation of threat-level probabilities p_t , which support the computation of elementary risks $R_t = p_t \times I_t$ and their aggregation into block-level scores R_b (Eq. 4) and the end-to-end score R_{E2E} defined in Section VI-A.

For each SLI, observable events translate qualitative requirements into analyzable parameters. Threat probabilities p_t are elicited from Table 2, and aggregated into R_b as per Eq. 4. Conformance is evaluated against qualitative SLOs, avoiding arbitrary numeric thresholds. SLIs are operational constructs linking design principles to measurable targets, while SLOs reflect normative expectations codified in established standards: NIST SP 800-63B, W3C VC Data Model 2.0/1.1, RFC 8446 (TLS 1.3), GDPR,

and HIPAA. This mapping ensures both analytic traceability and regulatory grounding, strengthening the framework’s auditability and accountability.

Table 2 defines SLIs as observable events implementing normative requirements across the four pipeline blocks: (i) **Device**: verified wallet compromise, session-binding failure or hijacking; (ii) **Infrastructure**: offline verification capability, status staleness, revocation delay; (iii) **Communication**: replay detection, authenticated message and credential provenance validation; (iv) **Services**: attribute over-disclosure and unauthorized-access events. SLOs are expressed qualitatively, aligned with existing standards and regulatory principles. At the **Device** level, NIST SP 800-63B defines Authenticator Assurance Levels (AAL2/AAL3) requiring phishing-resistant authenticators, non-exportable keys, and explicit user verification; OWASP provides session-hijacking guidance. At the **Infrastructure** level, the W3C VC Data Model 2.0 mandates verifier-local checks and freshness policies, while VC Status List 1.0 constrains revocation delays. For **Communication**, NIST SP 800-63B and TLS 1.3 enforce replay resistance and nonce-based freshness, while W3C VC Data Integrity 1.0 guarantees message authenticity. At the **Services** layer, GDPR Art. 5(1)(c) and HIPAA (45 CFR §164.502(b)) mandate data minimization, selective disclosure, and least-privilege access, as reinforced by OWASP Top 10 A01.

These sources ensure that the defined SLOs are normative, auditable, and resistant to arbitrary interpretation. SLI labels introduced here make such normative requirements empirically measurable. The threat-level probability parameter p (Eq. 1) informs block scores R_b (Eq. 4) and the overall risk R_{E2E} (Eq. 5).

Unlike SSI pipelines, EHR-based systems lack user-verifiable SLIs, relying instead on opaque SLAs and provider-controlled logs. This asymmetry is analyzed in Section VI-C using the comparative methodology of Subsection VI-A and the neutral pipeline defined in Subsection IV-B.

TABLE 2. Operational SLI/SLO mapping for the clinical pipeline (architecture-agnostic).

Block	SLI (observable metric)	SLO (target)	Measurement notes (feeds p_t)
DEVICE	Authenticator/wallet compromise events	Authenticators (e.g., SSI wallets; enterprise IdP factors) must rely on hardware-backed, phishing-resistant mechanisms with non-exportable keys and explicit user presence/verification.	p_t reflects the expected relative frequency of authenticator/wallet-compromise under the assumed threat model.
	Session-binding failures / hijacking incidents (NEW)	Sessions are strongly bound to the authenticator and to the authenticated actor; fixation/hijacking attempts must be detected and invalidated.	p_t models the expected rate of session-principal binding failures and hijacking attempts under server-side invalidation.
	Local isolation breaches	No unauthorized process should access wallet storage or cryptographic contexts.	p_t models the expected rate of runtime sandbox escapes / wallet API abuse.
INFRAST.	Verifier-local independence from upstream availability	Verifications must succeed under upstream unavailability via verifier-local trust artefacts.	p_t is the complement of the expected success proportion of verifier-local checks under unreachability assumptions.
	Authorization/credential status freshness and revocation-propagation delay	Revocation/status information remains fresh within a defined TTL; propagation delays are bounded and auditable.	p_t models the expected share of verifications exceeding the policy TTL for status freshness.
COMMUNICATION	Smart-contract verification failures	Credential status and revocation transactions complete without errors or invalid signatures.	p_t measures frequency of failed registry updates / invalid proofs.
	Replay detection mechanisms	Credential exchanges must enforce nonce, expiry, and audience binding to ensure replay resistance and freshness.	p_t reflects residual replay probability under the assumed model.
	Authenticated-message and credential-provenance validation failures (MitM/forgery residuals) (NEW)	All messages and credential artefacts are authenticated and integrity-protected; invalid exchanges do not yield valid credentials.	p_t quantifies the residual probability of channel-authentication failures or credential-signature/proof-verification failures.
SERVICES	Session continuity rate	Credential exchanges maintain stable secure channel completion (>99%).	p_t models the expected channel-drop frequency before exchange completion.
	Attribute over-disclosure events / consent-fatigue events	Disclosure must follow data-minimization principles with selective-disclosure and context-aware consent interactions.	p_t models the expected share of excessive-disclosure events or consent-fatigue-related errors.
	Unauthorized access (broken access control) events (NEW)	Least-privilege enforcement and isolation prevent unauthorized access at application, API, and data layers.	p_t measures the probability of policy-bypass or unauthorized access under the assumed threat model.
	Revocation propagation delay (app-layer)	Revoked credentials cease to validate within policy TTL.	p_t reflects the probability of credential use after revocation TTL.

Although real-world SSI-enabled Metaverse workflows may exhibit cross-block interactions (e.g., replay affecting disclosure, or freshness influencing consent), this work adopts an independence assumption across blocks for analytical tractability. Modeling systemic propagation across blocks is outside the present scope and is left as future work.

The selection of the SLI/SLO instrumentation follows directly from the architectural principles defined in Sections III and IV. Properties such as decentralization, non-custodial key management, verifier-local provenance guarantees, authenticated transport, and consent-driven selective disclosure determine which system behaviors must remain observable and which failure modes are admissible across the SSI-enabled pipeline. These principles constitute the normative foundation underlying the measurable constructs in Table 2 and ensure analytical traceability and methodological continuity for the risk-assessment model formalized in Section VI.

VI. RISK ASSESSMENT

The risk evaluation follows the guidelines of NIST SP 800-30 Rev. 1, harmonized with the NIST Risk Management

Framework (SP 800-37 Rev. 2) and the NIST Cybersecurity Framework 2.0, ensuring interoperability with enterprise-grade risk governance processes. The proposed risk-assessment framework is analytical and comparative by design. Its objective is to support architecture-level reasoning on security, resilience, and privacy exposure across alternative identity pipelines, rather than to provide empirical performance benchmarking. Large-scale experimental validation on production-grade XR platforms is currently constrained by the closed and proprietary nature of most Metaverse infrastructures. Consequently, probabilities and impacts are parameterized through observable Service-Level Indicators (SLIs) and normative Service-Level Objectives (SLOs) derived from established standards (e.g., NIST, W3C), ensuring methodological consistency, reproducibility, and auditability.

Building on the operational metrics defined in Subsection V-A, the analysis incorporates Service-Level Indicators (SLIs) and Service-Level Objectives (SLOs) as conceptual anchors for the elicited probability component p_t ; in this study, probability values are treated as modelling parameters and no field measurements

or operational logs are used (see Section VI-A). This observability asymmetry is analyzed in Subsection VI-C, following the architecture-agnostic pipeline defined in Section IV-B.

The assessment quantifies threats in a Metaverse health-care use case by instantiating a single architecture-agnostic clinical pipeline (Section IV-B) under two architectural profiles: an SSI profile (selective disclosure via Verifiable Presentations anchored in decentralized registries) and a traditional EHR profile (centralized access through provider-managed portals). Probabilities and impacts are parameterized using the SLIs/SLOs of Table 2; as clarified in Section VI-C, p_t values are modelling parameters (no field data). The resulting observability asymmetry is discussed in Section VI-C (Comparative Analysis).

A. METHODOLOGY

Each threat t is described by a probability of occurrence $p_t \in [0, 1]$, specified parametrically from the SLI/SLO framework (see Section V-A). These probabilities are non-empirical and are not derived from operational logs or field measurements. Each threat also has an impact score $I_t \in \{1, \dots, 5\}$ reflecting its severity on operational continuity, data security, and regulatory compliance. The elementary (atomic) risk at threat level is

$$R_t = p_t \times I_t, \quad R_t \in [0, 5]. \quad (1)$$

When an ordinal classification is required for probabilities, the decimal p_t is mapped to a five-level scale by taking the upper endpoint of the interval containing $5p_t$ and clamping to the admissible domain:

$$c = \min(5, \max(1, 5p_t)), \quad c \in \{1, \dots, 5\}. \quad (2)$$

For phase-level reporting (used in comparative tables), let ϕ denote a pipeline phase and T_ϕ the set of threats mapped to ϕ . The phase score is the arithmetic mean of elementary risks:

$$R_\phi = \frac{1}{|T_\phi|} \sum_{t \in T_\phi} R_t = \frac{1}{|T_\phi|} \sum_{t \in T_\phi} p_t I_t. \quad (3)$$

Risk is ultimately aggregated per macro-block of the taxonomy. Let $B = \{\text{Device, Infrastructure, Communication, Services}\}$ be the set of blocks and T_b the threats mapped to block b . The block-level score is

$$R_b = \frac{1}{|T_b|} \sum_{t \in T_b} p_t I_t. \quad (4)$$

In this formulation, R_b represents the arithmetic mean of the threat-level risks mapped to block b , ensuring comparability across blocks regardless of the number of threats; all threats are assumed equally weighted by default.

When empirical evidence indicates unequal relevance, Eq. 4 generalizes to a weighted mean:

$$R_b = \frac{\sum_{t \in T_b} w_t (p_t I_t)}{\sum_{t \in T_b} w_t}, \quad w_t \in [0, 1].$$

The end-to-end risk is normalized using the geometric mean, which ensures independence from block count and penalizes imbalanced profiles consistent with weakest-link sensitivity, where a single high-risk block dominates R_{E2E} . After computation, both R_b and R_{E2E} are clamped to the interval $[0, 5]$ to maintain alignment with the NIST SP 800-30 risk-scaling semantics:

$$R_{E2E} = \left(\prod_{b \in B} R_b \right)^{1/|B|}. \quad (5)$$

As a modelling baseline, risks associated with individual blocks are treated as independent. In practice, dependencies may exist (e.g., a communication failure preventing verification). Such effects can be explored via sensitivity analyses that assign proportionally greater weight to the dominant block (the one whose compromise has cascading consequences). This adjustment does not alter the reporting model: the end-to-end value remains the geometric mean over blocks (Eq. 5).

Probability and impact were each assessed using five-level qualitative scales, ranging from very low to very high. Probability classes correspond to indicative percentage intervals, while impact classes describe the potential operational and security consequences, from negligible to critical, including regulatory or safety implications. These scales support a consistent risk evaluation framework, where each level enables the normalization and scoring of risk values according to Eqs. (4)–(5).

B. CLINICAL PIPELINE

This section models a single, architecture-agnostic pipeline for clinical consultations in connected and XR-capable environments. Two actors interact, a requester (e.g., clinician) and a responder (e.g., patient), with optional support from identity, records, registry, and audit services. The pipeline abstracts requests, authorizations or consents, attestations or records, and logs, without assuming any specific identity or data-management stack. Each phase maps to one or more blocks of the risk taxonomy (Device, Infrastructure, Communication, Services).

1) P1—AUTHENTICATION AND SESSION BINDING (DEVICE, SERVICES)

The interaction begins with mutual authentication and the establishment of a fresh session bound to the authenticated state of each party. Control objectives include phishing-resistant authenticators, explicit user presence or verification when applicable, and robust session binding. Typical threats

at this stage comprise authentication compromise, credential or key-custody loss with availability impact, user impersonation or identity spoofing, and session hijacking or fixation.

2) P2—REQUEST AND TRANSPORT OF ACCESS REQUIREMENTS (COMMUNICATION)

The requester formulates the scope of access attributes, records, or documents and conveys it over an authenticated and confidential channel. Beyond integrity protection, the transport should guarantee freshness and replay resistance (for example, via nonce, expiry, and audience binding) and resist protocol downgrade or relay attempts. The primary threats in this phase are man-in-the-middle and replay attacks.

3) P3—AUTHORIZATION AND CONSTRUCTION OF THE RESPONSE (SERVICES)

The responder evaluates the request and authorizes a response consistent with declared purposes, either by granting consent or by constructing a proof or attestation. The emphasis is on purpose limitation, data minimization, disclosing only what is necessary, and user-driven, session-bound consent that prevents over-scoping. The predominant risk in this phase is unnecessary disclosure arising from overly broad authorizations or misaligned consent semantics.

4) P4—VERIFICATION AND CONTROLLED ACCESS (INFRASTRUCTURE, SERVICES)

The requester validates the response and, if successful, obtains controlled access to the relevant information. Verification entails provenance and integrity checks, assessment of status or revocation where applicable, least-privilege enforcement, and isolation between concurrent sessions. The salient threats at this stage are the acceptance of forged or falsified data and broken access control that could elevate privileges or bypass intended policy constraints.

5) P5—LOGGING AND AUDIT (INFRASTRUCTURE, SERVICES)

Events relevant to accountability are recorded in tamper-evident logs, with retention and transparency commensurate with regulatory requirements. Reliable timestamping, immutability properties adequate for audit, timely revocation propagation, and post-access governance (for example, token or session expiry) are essential control objectives. Corresponding threats include security logging, monitoring, and revocation failures, such as incomplete or alterable logs and revocation-lag that prolongs residual exposure.

6) CROSS-CUTTING CONSIDERATIONS AND EXTENSIBILITY

System unavailability stemming from denial-of-service, downtime, or misconfiguration can affect multiple phases and blocks with heterogeneous impact; architectural choices such as redundancy, graceful degradation, and verifier-local operation with cache-warm status information help mitigate these effects without altering the phase structure. The abstraction cleanly separates what happens at each step from how it is implemented, so centralized portals, decentralized

credentials, or hybrid models can instantiate the same phases and be mapped back to the Device, Infrastructure, Communication, and Services blocks without modifying the underlying control objectives.

C. COMPARATIVE AND AGGREGATED RISK ANALYSIS

This section instantiates the clinical pipeline of Section IV-B under two deployment profiles (SSI vs. traditional EHR) and applies the risk model of Section VI-A. Numerical values are illustrative modelling proxies: probabilities $p \in [0, 1]$ are obtained from the SLI/SLO framework of Table 2, and impacts $I \in \{1, \dots, 5\}$ follow the qualitative scale defined in Section VI-A.

For each threat t , we compute $R_t = p_t \times I_t$; phase scores are arithmetic means of mapped threats, while block-level risks summarize Device, Infrastructure, Communication, and Services. The end-to-end score RE_{2E} is the geometric mean across blocks.

At the *Device* layer, SSI benefits from phishing-resistant authenticators, hardware-backed keys, and explicit user presence, reducing impersonation and session-compromise likelihood relative to browser/SSO-based EHR access. Emerging exposure remains tied to device-local sandbox integrity, mitigated through attested runtimes and scoped APIs. At the *Infrastructure* layer, verifier-local independence and revocation freshness reduce cascading verification failures in SSI, whereas centralized EHR deployments concentrate failure modes and provenance risks. At the *Communication* layer, both use secure transport, but SSI adds artefact-level binding (nonce, expiry, audience, provenance), lowering replay and forgery likelihoods beyond typical EHR JWT-based integrations. At the *Services* layer, SSI enforces consent-bound selective disclosure with tamper-evident auditability, reducing over-disclosure and silent policy violations compared to broader EHR authorization scopes.

Aggregated results show SSI distributing residual risk across blocks with bounded Infrastructure exposure, while EHR concentrates systemic exposure in Infrastructure and Services due to centralization and broader disclosure surfaces. Differences trace directly to measurable SLI/SLO evidence (Table 2) rather than subjective assumptions, preserving interpretive coherence.

From Table 3, the average per-phase elementary risks (arithmetic mean of threats in the phase) are:

$$\begin{aligned} \text{SSI: } P1 &= 0.800, P2 = 0.567, P3 = 0.400, \\ P3_4 &= 0.400, P4 = 0.500, P5 = 0.600; \\ \text{EHR: } P1 &= 1.900, P2 = 1.100, P3 = 3.200, \\ P3_4 &= 2.400, P4 = 2.200, P5 = 1.800. \end{aligned}$$

The subsequent analysis aggregates the phase-level outcomes by architectural block and normalizes them end-to-end. Block-level scores R_b are obtained by aggregating elementary risks $R_t = p_t \times I_t$ across the threats mapped to

TABLE 3. Threat-level risk entries by pipeline phase (SSI vs EHR).

Phase	Threat	SSI		EHR	
		p_t	I_t	p_t	I_t
1	Authentication compromised	0.20	4	0.50	4
1	Key custody/credential loss	0.50	3	0.50	3
1	User impersonation	0.30	4	0.80	4
1	Session-binding failure / hijacking	0.20	3	0.60	3
1	Local-isolation breach (sandbox escape)	0.10	3	0.30	3
All	System unavailable	0.30	2	0.50	2
2	MitM / forgery residuals (channel)	0.30	3	0.30	3
2	Replay attack / freshness failure	0.20	3	0.50	3
2	Session-continuity failure	0.10	2	0.30	2
3	Over-disclosure of attributes / consent-fatigue	0.10	4	0.80	4
3–4	Forged data/credential accepted (provenance/status failure)	0.10	4	0.60	4
4	Unauthorized access (broken access control)	0.20	3	0.70	3
4	Smart-contract verification failure	0.10	4	0.40	4
5	Logging / monitoring and revocation-lag failures	0.20	3	0.60	3

each macro-block (Device, Infrastructure, Communication, Services), while the end-to-end risk R_{E2E} follows the geometric composition described in Section VI-A. Probability elicitation and qualitative targets remain anchored to the SLI/SLO instrumentation of V-A (Table 2), ensuring methodological continuity.

The Table 4 presents a comparative analysis of block-level risk values between the SSI and EHR pipelines, highlighting significant differences in security exposure across architectural components. Overall, the SSI framework exhibits consistently lower risk levels across all blocks (i.e., Devices, Infrastructure, Communication, and Services) indicating a more resilient and privacy-preserving identity architecture.

Specifically, the Device block shows the highest risk in both systems; however, SSI reduces this value to 0.800 compared with 1.900 in EHR, suggesting enhanced protection of authentication and credential custody mechanisms. Similarly, Infrastructure and Communication layers display a marked decrease in risk under the SSI model, reflecting improved decentralization and reduced dependency on centralized trust anchors. The Services block shows moderate residual risk (0.533) in SSI, still considerably lower than that of EHR (2.600), primarily due to user-controlled consent and selective disclosure mechanisms.

The Table 5 provides a comparative overview of end-to-end risk levels (R_{E2E}) for the SSI and EHR pipelines, summarizing their overall security posture within the evaluated framework. The results indicate that the SSI architecture achieves a significantly lower cumulative risk value ($R_{E2E} = 0.580$), considered as a *Low Risk* band (Level 1). This outcome reflects the benefits of decentralized identity management, user-controlled consent, and reduced reliance on centralized intermediaries.

Conversely, the EHR pipeline records a higher end-to-end risk score ($R_{E2E} = 1.735$), considered a *Moderate Risk* band (Level 2). This higher exposure is primarily attributed to centralized credential storage, weaker trust distribution, and greater vulnerability to systemic failures.

VII. DISCUSSION AND LIMITATION

The comparative results discussed in Section VI-C confirm that the proposed SSI-enabled architecture achieves a measurable reduction of end-to-end risk across the Device, Communication, and Services blocks. These outcomes substantiate the hypothesis that decentralized credential exchange, verifier-local independence, and cryptographic provenance jointly reduce systemic exposure in XR pipelines by eliminating single points of failure and minimizing over-disclosure of user data. The quantitative improvements observed in Tables 4 and 5 stem directly from the Service-Level Indicators and Objectives (SLIs/SLOs) introduced in Table 2, which operationalize measurable attributes such as authenticator assurance, freshness of status information, replay resistance, and audit-trail integrity. By grounding probability parameters p_t and impacts I_t in these observables, the risk assessment translates qualitative security requirements into traceable quantitative outcomes.

Compared with conventional federated or centralized identity solutions such as OAuth 2.0, OpenID Connect, or SAML-based single sign-on, SSI offers structural advantages that directly influence these SLI-anchored probabilities. Its decentralized credential exchange removes reliance on third-party identity providers as single points of failure and confines breach propagation to the local verifier domain. Verifier-local independence and cryptographic provenance constrain the effective likelihood of forged or stale artefacts, while selective-disclosure credentials and session-bound

consent implement data minimization at protocol level, lowering p_t for threats such as impersonation, session hijacking, and over-disclosure. These mechanisms explain the lower block-level risks measured in Tables 4 and 5, particularly in the Device, Communication, and Services domains, and justify SSI as a more resilient and privacy-preserving alternative to current federated identity infrastructures.

Nevertheless, the current implementation remains bounded by architectural, methodological, and ecosystem constraints that delimit its immediate deployability. From an architectural standpoint, contemporary Metaverse platforms, including Horizon Worlds, VRChat, Roblox, and Spatial, still rely on proprietary or federated identity stacks incompatible with decentralized identifiers and verifiable credentials. Even Web3-oriented environments such as Decentraland or Somnium Space provide only partial DID/VC support and lack interoperable agent channels, preventing verifiable, user-controlled credential exchange. As a consequence, the integration of the proposed SSI stack is currently feasible only within controlled Unity-based prototypes and cannot yet be validated under closed-source governance models or multi-engine deployments. This constraint exposes a structural asymmetry between the openness required by SSI and the proprietary ecosystems dominating current XR infrastructures.

The same asymmetry extends to the regulatory layer. While initiatives such as eIDAS 2.0 and the European Digital Identity Wallet promote verifiable and privacy-preserving identity frameworks, they remain anchored to centralized trust hierarchies and regulated issuers. The coexistence of institutional compliance and user sovereignty thus defines a persistent tension that hinders the operational adoption of SSI in critical domains such as healthcare and finance, precisely the contexts where the proposed framework offers the highest normative payoff. Moreover, the absence of universally adopted W3C DID and VC profiles, heterogeneous revocation models, and fragmented trust-registry governance continue to impede seamless interoperability across Metaverse platforms. These divergences indicate that technical standardization and regulatory convergence must evolve jointly if SSI is to become a production-grade trust substrate for immersive environments.

TABLE 4. Comparison of block-level risk values (R_b) between SSI and EHR pipelines.

R_b	Device	Infrastructure	Communication	Services
SSI	0.800	0.467	0.567	0.533
EHR	1.900	1.667	1.100	2.600

TABLE 5. End-to-end risk comparison and bands.

Profile	R_{E2E}	Risk band	Level
SSI	0.580	$R < X \rightarrow$ Low Risk	1
EHR	1.735	$X \leq R < Y \rightarrow$ Moderate Risk	2

Methodologically, the quantitative model developed in Section VI is not yet calibrated on empirical telemetry.

This approach ensures internal coherence and reproducibility but precludes direct observation of runtime metrics such as latency, throughput, and verifier availability under real XR workloads. The geometric aggregation of block-level scores further assumes independence among macro-domains, an approximation that may underestimate correlated vulnerabilities in coupled pipelines. To refine the analytical precision of the model, future studies should deploy instrumented testbeds capable of collecting runtime indicators (e.g., p95 latency, DIDComm packet loss, revocation-status TTL) and use them to calibrate probability distributions and sensitivity functions, enhancing the correspondence between observed SLIs and computed risk.

Implementation boundaries likewise constrain the current demonstrator. The Unity-based prototype was selected for reproducibility and toolchain maturity but limits portability toward Unreal Engine, WebXR, and mobile runtimes. The wallet and agent modules currently operate at application level without hardware-anchored key isolation (e.g., TPM 2.0 or Secure Enclave), reducing compliance with NIST SP 800-63B AAL3 requirements and constraining achievable assurance levels. Integrating such hardware-backed primitives would strengthen authenticator assurance and allow a more realistic estimation of Device-layer risk in Table 8, where authentication compromise remains a dominant contributor.

Looking forward, three trajectories appear most promising. First, cross-platform interoperability should be pursued by extending wallet and agent components to Unreal Engine and WebXR through standardized DIDComm v2 interfaces. Second, empirical performance benchmarking should integrate telemetry hooks for measuring cryptographic latency, message throughput, and scalability of SSI interactions in live XR sessions. Third, stronger standard alignment and governance integration should be achieved by contributing to W3C VC DM 2.0 and DID Core initiatives while harmonizing SSI with eIDAS 2.0 trust frameworks to enable hybrid public-private trust anchors. These efforts would simultaneously improve technical maturity and regulatory acceptability, bridging the gap between conceptual validation and operational deployment.

VIII. CONCLUSION

This work presented a modular self-sovereign identity (SSI) architecture for secure and privacy-preserving data exchange in XR and Metaverse environments, grounded in measurable Service-Level Indicators (SLIs) and Service-Level Objectives (SLOs). The results in Section VI-C show that SSI yields consistently lower block-level and end-to-end risk than federated or centralized identity models, with clear improvements in the Device, Communication, and Services domains. These findings indicate that decentralization, cryptographic provenance, and selective disclosure can operate as quantifiable controls for reducing systemic exposure in latency-sensitive XR ecosystems. A central contribution lies in demonstrating that

data minimization, traditionally viewed as a legal principle, can be operationalized as a measurable design property. Through selective disclosure, predicate-based proofs, and session-bound consent, users disclose only what is necessary for a given interaction, reducing privacy exposure while preserving interoperability. This reframes data minimization as an actionable capability aligned with regulatory principles (e.g., GDPR, HIPAA) rather than a declarative guideline. Methodologically, this work formalized a risk-assessment process that maps SLOs to empirical observables, enabling the computation of probabilities and impacts as verifiable resilience metrics. This approach narrows the gap between qualitative assurance frameworks and quantitative evidence. Future research will strengthen this calibration through instrumented testbeds collecting operational telemetry (e.g., latency, revocation-status freshness, DIDComm reliability) and extend design validation to cross-engine interoperability, hardware-anchored key protection, and machine-readable compliance automation. Overall, the results indicate that Self-Sovereign Identity can operate as a viable security and trust substrate for networked XR and Metaverse systems, reducing systemic risk through decentralized provenance, selective disclosure, and verifier-local independence. Beyond regulatory compliance, the proposed architecture demonstrates how digital identity can be treated as a measurable and enforceable control plane for interoperability, resilience, and privacy in latency-sensitive immersive environments. The analytical risk assessment grounded in SLIs and SLOs further shows that security and data-minimization properties can be quantified and compared across alternative identity pipelines. Future work will focus on empirical telemetry collection, cross-engine validation, and tighter integration with emerging trust frameworks to further strengthen the deployment readiness of SSI-enabled immersive applications.

REFERENCES

- [1] G. D. Ritterbusch and M. R. Teichmann, "Defining the metaverse: A systematic literature review," *IEEE Access*, vol. 11, pp. 12368–12377, 2023.
- [2] A. Koochang et al., "Shaping the metaverse into reality: A holistic multidisciplinary understanding of opportunities, challenges, and avenues for future investigation," *J. Comput. Inf. Syst.*, vol. 63, no. 3, pp. 735–765, May 2023.
- [3] D. Pöhn, M. Grabatin, and W. Hommel, "EID and self-sovereign identity usage: An overview," *Electronics*, vol. 10, no. 22, p. 2811, Nov. 2021.
- [4] C. Mazzocca, A. Acar, S. Uluagac, R. Montanari, P. Bellavista, and M. Conti, "A survey on decentralized identifiers and verifiable credentials," *IEEE Commun. Surveys Tuts.*, vol. 27, no. 6, pp. 3641–3671, Dec. 2025.
- [5] K. A. M. Ahmed, S. F. Saraya, J. F. Wanis, and A. M. T. Ali-Eldin, "A blockchain self-sovereign identity for open banking secured by the customer's banking cards," *Future Internet*, vol. 15, no. 6, p. 208, Jun. 2023.
- [6] A. A. Torongo and M. Toorani, "Blockchain-based decentralized identity management for healthcare systems," 2023, *arXiv:2307.16239*.
- [7] J. Fang, T. Feng, X. Guo, and X. Wang, "Privacy-enhanced distributed revocable identity management scheme based self-sovereign identity," *J. Cloud Comput.*, vol. 13, no. 1, p. 154, Nov. 2024.
- [8] J. Yin, Y. Xiao, J. Feng, M. Yang, Q. Pei, and X. Yi, "DidTrust: Privacy-preserving trust management for decentralized identity," *IEEE Trans. Dependable Secure Comput.*, vol. 22, no. 3, pp. 3105–3120, May 2025.
- [9] T.-J. Chuang and S. Smith, "A multi-user cross-platform hands-on virtual lab within the metaverse—The case of machining training," *Virtual Reality*, vol. 28, no. 1, p. 62, Mar. 2024.
- [10] M. Naghmouchi and M. Laurent, "Privacy by design for self-sovereign identity systems: An in-depth component analysis completed by a design assistance dashboard," 2025, *arXiv:2502.02520v1*.
- [11] G. Wang, A. Badal, X. Jia, J. S. Maltz, K. Mueller, K. J. Myers, C. Niu, M. Vannier, P. Yan, Z. Yu, and R. Zeng, "Development of metaverse for intelligent healthcare," *Nature Mach. Intell.*, vol. 4, no. 11, pp. 922–929, 2022.
- [12] G. Bansal, K. Rajgopal, V. Chamola, Z. Xiong, and D. Niyato, "Healthcare in metaverse: A survey on current metaverse applications in healthcare," *IEEE Access*, vol. 10, pp. 119914–119946, 2022.
- [13] L. Yang, Y. Xu, and P. Hui, "Framing metaverse identity: A multidimensional framework for governing digital selves," *Telecommun. Policy*, vol. 49, no. 3, Apr. 2025, Art. no. 102906.
- [14] M. Dupont and C. Rossi, "The interplay between policy and technology in metaverses: Towards seamless avatar interoperability using self-sovereign identity," *Proc. Int. Conf. Digit. Governance*, 2023, pp. 210–225.
- [15] R. Kumar and S. Almeida, "Self-sovereign identity for trust and interoperability in the metaverse," *J. Blockchain Appl. Virtual Worlds*, vol. 5, no. 1, pp. 34–52, 2023.
- [16] T. Nguyen and P. Garcia, "Ssibac: Self-sovereign identity-based access control," *IEEE Trans. Inf. Secur. Privacy*, vol. 18, no. 4, pp. 980–995, Apr. 2023.
- [17] B. Ramić, E. Cogo, I. Prazina, E. Cogo, M. Turkanović, R. T. Mulahasanović, and S. Mrdović, "Selective disclosure in digital credentials: A review," *ICT Exp.*, vol. 10, no. 4, pp. 916–934, Aug. 2024.
- [18] R. Laborde, A. Ferreira, C. Lepore, M. A. Kandi, M. Sibilla, and A. Benzekri, "The interplay between policy and technology in metaverses: Towards seamless avatar interoperability using self-sovereign identity," in *Proc. IEEE Int. Conf. Metaverse Comput., Netw. Appl. (MetaCom)*, 2023, pp. 418–422.
- [19] C. Sandeepa, S. Wang, and M. Liyanage, "Privacy of the metaverse: Current issues, AI attacks, and possible solutions," in *Proc. IEEE Int. Conf. Metaverse Comput., Netw. Appl. (MetaCom)*, Jun. 2023, pp. 234–241.
- [20] R. T. Moreno, J. García-Rodríguez, J. B. Bernabé, and A. Skarmeta, "A trusted approach for decentralised and privacy-preserving identity management," *IEEE Access*, vol. 9, pp. 105788–105804, 2021.
- [21] A. Mühle, A. Grüner, T. Gayvoronskaya, and C. Meinel, "A survey on essential components of a self-sovereign identity," *Comput. Sci. Rev.*, vol. 30, pp. 80–86, Nov. 2018.



SALVATORE SAIU received the M.D. degree in economics and new technologies and the Ph.D. degree in law and economics of production systems from the University of Sassari, Italy, in 2010 and 2016, respectively. From 2018 to 2022, he was a Research Fellow in information processing systems with the University of Sassari. Since 2023, he has been a Fixed-Term Assistant Professor of computer engineering with the Department of Engineering, University of Sassari. His research interests include self-sovereign identity, decentralized and privacy-preserving identity architectures, secure authentication and credential management, and data governance in extended reality and metaverse environments, with particular attention to human-centered and healthcare-oriented applications.



MAURO FADDA (Senior Member, IEEE) is currently an Associate Professor of telecommunications with the Engineering Department, University of Sassari, Sassari, Italy. Previously, he was an Assistant Professor with the Department of Electrical and Electronic Engineering, University of Cagliari. He spent a period as a Visiting Ph.D. Student with the Department of Electronics and Telecommunications, Faculty of Engineering of Bilbao, University of the Basque

Country (UPV/EHU), Leioa, Spain, in 2012. In 2020, he was a short-term Visiting Professor with the Department of Electronics and Computers, Transylvanian University of Brasov, Brasov, Romania. He has co-authored an extensive list of papers published in journals and international conference proceedings. His current research focuses on telecommunications issues, cognitive radio systems, signal processing for radio communications, the transmission and processing of multimedia data, and state-of-the-art digital systems. He has been a member of the National Interuniversity Consortium for Telecommunications (CNIT), since 2011. In March 2020, he was the elected Chair of the Italian chapter of the Broadcast Technology Society of the Institute of Electrical and Electronics Engineers (IEEE). He has served as the chair for various international conferences and workshops. He is an Associate Editor for IEEE ACCESS and the Topic Editor for *Sensors* (MDPI).



ENRICO GROSSO was born in Serravalle Scrivia, Italy, in November 1963. He received the degree in electronic engineering and the Ph.D. degree in computer science and electronic engineering from the University of Genoa, in 1988 and 1993, respectively. Since 1988, he has been involved as a Project Investigator and a Project Manager in various research actions funded by the European Community. Since 1990, he has been visiting the National Institute of Scientific Research LIFIA of

Grenoble, France. In 1992, he was a Visiting Scientist with the Department of Computer Science, University of Rochester, Rochester, NY, USA. In 2002, he joined the University of Sassari, where he is currently a Full Professor of computer engineering and the Director of the Engineering Department and the Computer Vision Laboratory. His main research interests cover image processing, biological and artificial vision, and biometrics.

...



PIETRO RUIU received the Ph.D. degree in electrical, electronics, and communications engineering, and the master's degree in telecommunications engineering from the Polytechnic of Turin, in 2006 and 2018, respectively. He is currently a Research Fellow (tenure track) with the Engineering Department, University of Sassari, with main interests on computer vision, artificial intelligence, and computing infrastructures. From 2013 to 2018, he was the Head of the Infrastructures and Systems

for Advanced Computing (IS4AC) Research Unit, LINKS Foundation, with main interests in heterogeneous infrastructures, cloud automation, data privacy, energy efficiency of computing, and network resources. From 2007 to 2013, he was a Researcher with Istituto Superiore Mario Boella (ISMB), in the field of computing infrastructure, studying technologies, such as cloud computing, grid computing, high-performance computing (HPC), and virtualization. He was an Organizer and a TPC member in several international conferences and workshops.